ĐẠI HỌC BÁCH KHOA HÀ NỘI
VIỆN CÔNG NGHỆ THÔNG TIN VÀ TRUYỀN THÔNG

Nhập môn An toàn thông tin

Chương Mở đầu. **Giới thiệu chung về lĩnh vực và môn học**

Lịch trình

- Tiếp cận từ ngoài vào trong:

Những hiểu biết cơ bản của người quản lý doanh nghiệp về các yêu cầu cho GP ATTT

  - Ba mục tiêu chính của một giải pháp ATTT
  - Các mối đe dọa
  - Chính sách và cơ chế
  - Biện pháp đảm bảo
  - Các vấn đề về vận hành và nhân sự
  - Vòng đời ATTT
- Tiếp cận từ bên trong: *Góc độ kỹ thuật – hiểu biết của một kỹ sư ATTT*
- *Tổng quan về môn học*

Mục tiêu ATTT

Có 3 mục tiêu chính của một giải pháp ATTT xây dựng cho một hệ thống thông tin phục vụ cho 1 tổ chức/doanh nghiệp nào đó

- Bảo mật (Confidentiality)
  - Đảm bảo tính mật: che giấu các thông tin và dữ liệu
- Đảm bảo tính nguyên vẹn (Integrity)
  - Data integrity: dữ liệu, thông tin không thể bị bóp méo mà không bị phát hiện
    - VD: gói tin gửi qua các router trung gian có thể bị can thiệp bóp méo, người nhận cần phát hiện để không chấp nhận thông tin sai lệch (bị lừa)
  - Origin integrity (Authentication)
    - Bóp méo danh tính người tạo và gửi tin, giả mạo
- Tính khả dụng (Availability)
  - Đảm bảo truy nhập sẵn sàng đến tài nguyên thông tin hệ thống
    - Ví dụ: tấn công DoS là điển hình chống phá mục tiêu này

Phân loại các mối đe dọa

- Bóc trần (Disclosure)
  - Kẻ địch xem lén, nghe trộm (Snooping) các thông tin riêng tư, mật
- Lừa đảo (Deception)
  - Sửa đổi (Modification), Chế giả (spoofing), từ chối đã gửi hoặc nhận (repudiation of origin, denial of receipt)
    - VD: điển hình là thông qua can thiệp bóp méo làm giả các gói tin, thông điệp chuyển phát giữa các bên
- Gây gián đoạn (Disruption)
  - Thông qua tấn công sửa đổi bóp méo
- Chiếm đoạt, phá hỏng (Usurpation)
  - Thông qua tấn công bóp méo, làm giả đối với các gói tin hệ thống,
  - VD điển hình: tấn công từ chối dịch vụ (denial of service – DoS)

Tấn công xem lén (Snooping)

- Can thiệp trái phép vào thông tin – bóc trần.
  - Dạng thụ động: nghe, xem trộm trên các kênh truyền tin …
    - (Passive) wiretapping: các gói tin truyền trên mạng bị nghe/xem lén – hacker có thể nằm ở các router (máy chủ định tuyến trung gian) – kẻ có thể tự do can thiệp khi có nhiệm vụ chuyển tiếp gói tin
    - Cần hiểu rõ nguyên lý packet switching của Internet
  - Biện pháp khắc phục là sử dụng các dịch vụ bảo mật (Confidentiality services).

Tấn công sửa đổi (Modification)

- Là sửa đổi hay bóp méo các thông điệp/gói tin, nằm trong cả 3 hình thức đe dọa cuối
  - Lừa đảo (Deception): thông tin sai lệch có thể được chấp nhận như chính xác, từ đó dẫn đến quyết định sai.
  - Gián đoạn hay chiếm đoạt: nếu kẻ địch tấn công bóp méo lên dữ liệu điều khiển, can thiệp vào hệ điều hành …
- *Active wiretapping* là hình thức phổ biến khi dữ liệu bị bóp méo khi đang tham gia giao thông mạng.
  - Ví dụ: tấn công kẻ-ngồi-giữa (the man-in-the-middle attack)
- Giáp pháp: Các dịch vụ bảo đảm tính nguyên vẹn (Integrity services).

Tấn công kẻ-ngồi-giữa

- The man-in-the-middle attack
- Kẻ xâm nhập (intruder) tìm cách nghe trộm và sửa đổi cả 2 luồng thông điệp giữa 2 bên gửi & nhận sao cho thông tin bóp méo 2 chiều vẫn khớp nhau và không làm cho 2 bên phát hiện được
  - Hai bên gửi & nhận không thể phát hiện được, kẻ xấu có thể hưởng lợi bằng việc nghe trộm và bóp méo, có thể lừa đảo và thắng lợi cho kẻ xấu

Tấn công từ chối đã gửi

- Kẻ tấn công phủ nhận đã phát/gửi/tạo ra một dịch vụ hay đơn đặt hàng ....
  - Example: suppose a customer => a letter agreeing to pay for a product => the vendor ships the product and then demands payment => the customer denies having ordered the product and keep the unsolicited shipment without payment.
  - Cần chống lại bằng các cơ chế đảm bảo tính nguyên vẹn.

Tấn công từ chối dịch vụ (Denial of service)

- Mục đích của kẻ tấn công: gây gián đoạn dài hạn thậm chí không thể tiếp cận được từ users đối với máy chủ nạn nhân.
  - Cơ chế tấn công phổ biến: chiếm đoạt lưu lượng giao thông đến máy chủ bằng một "dòng thác" các gói tin giả mạo, có thể vô nghĩa, làm kiệt quệ tài nguyên xử lý (CPU) hoặc đường truyền (băng thông) – thực hiện qua các máy tay sai thường là bị chiếm quyền điều khiển và bị sai khiến
    - Có thể tổ chức cả 1 đội quân các máy tay sai (bot net), tấn công vô thức (người chủ thực sự các máy tính này không hề biết đến): tấn công DDoS
  - Giải pháp: xây dựng các cơ chế đảm bảo tính khả dụng (availability).

Chính sách và cơ chế

- Chính sách (Policy): phát biểu những yêu cầu khái quát về ATTT
  - Tập hợp các phát biểu này xác định thế nào là "security" đối với một doanh nghiệp, một hệ thống thông tin cụ thể.
- Cơ chế (Mechanisms) là biện pháp kỹ thuật để thực thi áp đặt Chính sách
- Kiện toàn hệ thống chính sách
  - Các chính sách riêng biệt có thể đến từ nhiều góc độ chuyên môn, từ các chuyên gia/quản lý lĩnh vực chuyên môn khác nhau trong tổ chức, doanh nghiệp; Một ủy bản xây dựng tập chính sách thường hình thành từ lãnh đạo/quản lý các bộ phận quan trọng trong tổ chức
  - Nếu các chính sách có sự mâu thuẫn, các sự khác biệt, "sự vênh", sẽ làm tạo ra những khe hở -- cái thường được gọi là lỗ hổng ATBM (security vulnerabilities)

Chính sách và cơ chế

- Các chính sách có thể được thể hiện thông qua
  - Ngôn ngữ tự nhiên, dễ hiểu nhưng có thể thiếu chính xác
  - Công thức logic toán, chính xác nhưng thường khó hiểu;
  - Ngôn ngữ chính sách, khá tương tự ngôn ngữ lập trình, có thể làm cân bằng đòi hỏi về tính chính xác và dễ hiểu

Chính sách và cơ chế

- Cơ chế bao gồm các yếu tố
  - Khía cạnh kỹ thuật thiết lập các điều khiển trong hệ thống chương trình máy tính để đáp ứng các chính sách,
    - Vd: cơ chế mật khẩu với các quy tắc phù hợp để đáp ứng chính sách đăng nhập chỉ cho user hợp lệ, một cách an toàn.
  - Khía cạnh thủ tục, các kiểm soát bên ngoài hệ thống máy tính;
    - Vd: sa thải nhân viên mang đĩa/ chương trình game vào công ty từ nguồn không đáng tin cậy

Biện pháp kiểm soát

- Assurance: biện pháp kiểm soát mức độ thành công trong bảo đảm hệ thống (cơ chế) sẽ đáp ứng các yêu cầu (chính sách) đến mức độ cao như yêu cầu (how much you can trust the system to do what it is supposed to do).
- Các kỹ thuật kiểm soát:
  - Đặc tả
  - Thiết kế
  - Cài đặt

Đặc tả

- Specification:
  - Được tạo ra từ việc phân tích yêu cầu hệ thống (Requirements analysis)
  - Là những phát biểu về tính năng mong muốn: nêu những gì hệ thống cần thực hiện để đáp ứng yêu cầu đặt ra. Có thể biểu đạt
    - Rất hình thức (logic toán) or phi hình thức (qua NNTN)
    - Mức khái quát cao (high-level) hay thấp (low-level), tức là chi tiết và gần với mức cài đặt
      - describing what the system as a whole is to do vs. what specific modules of code are to do

Thiết kế và Cài đặt

- Thiết kế (Design): How to meet specification
  - Người ta thường tạo ra nhiều mức thiết kế, trong đó sẽ tạo ra khung nhìn hệ thống theo nhiều mức khái quát (abstractions), và làm mịn (refining) dần, từ mức khái quát cao nhất đến mức thấp nhất –mức thiết bị phần cứng và cơ sở vật chất.
  - Cần có chuyên gia phân tích để luận giải sự phù hợp của hệ thống các mức thiết kế này phù hợp với đặc tả..
- Cài đặt (Implementation)
  - Công việc lập trình (coding) để tạo ra các module chương trình phần mềm.
    - Lập trình theo các bản thiết kế mức thấp.
    - Sự hợp nhất của các module này phải thỏa mãn bản thiết kế chung.

Các vấn đề vận hành

- Phân tích giá thành-lợi nhuận (Cost-Benefit Analysis)
  - Các giải pháp ATTT với các tập mục tiêu cao thấp khác nhau có thể được đề xuất (bởi công ty tư vấn chuyên nghiệp) để nhà đầu tư lựa chọn tùy theo ngân sách và tài nguyên cho phép
- Phân tích nguy cơ (Risk Analysis)
  - Cần thực sự bảo vệ cái gì?
  - Mức độ bảo vệ cho nó?
- Luật và lệ (Laws and Customs)
  - Chính sách ATTT có thể phù hợp với luật và lệ nơi (quốc gia) này nhưng lại trái với luật lệ nơi khác
  - VD. Công thê đa quốc gia có thể gặp nhiều khó khăn Google đã phải rút khỏi thị trường Trung quốc và chấp nhận mất mát lớn do đầu tư rất nhiều sau 5 năm.

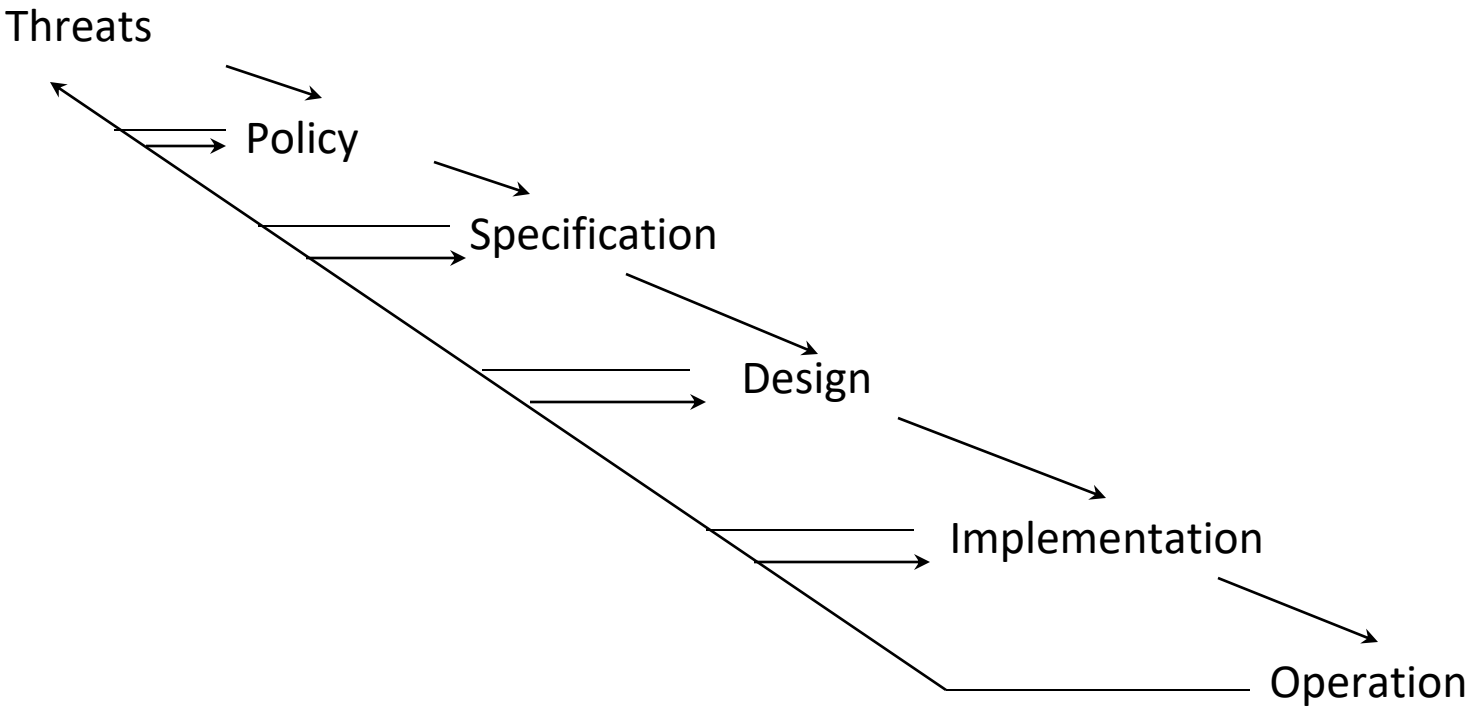
Vấn đề con người

- Các vấn đề tổ chức
  - Trách nhiệm và quyền lực
    - Những người giữ trách nhiệm quan trọng về đảm bảo ATTT cần phải có quyền lực tương xứng
  - Lợi ích tài chính
    - Điều "ngang trái": đầu tư ATTT không phải lại động cơ lợi nhuận trực tiếp, người ta chỉ thực sự thấm thía đáp ứng khi đã bị mất mát thiệt hại

Vấn đề con người

- Vấn đề về con người
  - Xây dựng GP ATTT phải tính đến 2 loại đối tượng tấn công có thể: bên ngoài (outsiders) và bên trong (insiders); loại thứ 2 có thể tính đến những người làm cũ, đối tượng bị sa thải …
  - Chế tạo giả quan hệ xã hội (Social engineering): lợi dụng hiểu biết và quan hệ để lừa đảo

Vòng đời (lifecycle) GPATTT



Một ví dụ thực tế -- outdated

- A major corporation decided to improve its security.
  - Hired consultants => determined the threats => created a policy => derived specifications that the security mechanisms had to meet => developed a design that would meet the specifications.
- During the implementation phase
  - discovered [modems to the telephones] => firewall => the design had to be modified to divide systems into two classes: outside or behind the firewall

- When deployed, the operation and maintenance phase revealed several unexpected threats.
  - sensitive data sent across the Internet in the clear crypto is very difficult to use fixed implementation
  - several "trusted" hosts (allowed to log in without authentication) were physically outside the company'control
    - This violated policy, because of commercial reasons modified the policy element about "trusted hosts"
  - Finally, the company detected proprietary material being sent to a competitor over electronic mail.
    - This added a threat that the company had earlier discounted. The company did not realize that it needed to worry about insider attacks.

Nhìn lại một số điểm chính

- Tập chính sách giúp định nghĩa thế nào là ATTT cho 1 tổ chức/doanh nghiệp cụ thể, cơ chế kỹ thuật là công cụ áp đặt chính sách đó
- Ba mục tiêu chính của GPATTT: đảm bảo cho
  - Tính mật -- Confidentiality
  - Tính nguyên vẹn -- Integrity
  - Tính sẵn dùng -- Availability
- Tầm quan trọng của biện pháp kiểm soát
- Yếu tố con người

Phần II
Góc nhìn từ bên trong – của một kỹ sư ATTT

Tầm nhìn

Làm chủ kiến thức về ATTT của các hệ thống hiện hành, bao gồm các mặt liên quan

- Điểm yếu – lỗ hổng an toàn (vulnerabilities)
- Mối đe dọa (kịch bản tấn công tiềm năng)
- Tấn công (thực sự đã xảy ra)
- Các công cụ kiểm soát (security measures)

Các biện pháp kiểm soát

- Công cụ mật mã (Encryption)
- Kiểm soát bằng phần mềm (Software controls)
- Kiểm soát bằng thiết bị (Hardware controls)
- Chính sách và thủ tục (Policies and procedures)
- Kiểm soát thông qua hệ thống CSVC

Người kỹ sư ATTT cần nắm vững

- Nắm vững các kiến thức và công cụ nền tảng ATTT bao gồm kiến thức mật mã căn bản & các kỹ thuật liên quan, các phương pháp xác thực, các phương pháp quản lý truy nhập, và một số kiến trúc ATTT khác
- Trên nền cơ bản đó phát triển một kiến thức chuyên gia ATTT trong một số lĩnh vực quan trọng:
  - Mạng máy tính
  - CSDK và khai phá dữ liệu (Databases and data mining)
  - Xây dựng phần mềm & chương trình máy tính
  - Web và các dịch vụ Internet
  - Tính thương tư và đảm bảo an toàn trong thương mại điện tử

Khoa học mật mã

- Lĩnh vực hướng tới xây dựng các phương pháp hình thức (formal methods) – bằng mô hình toán học – cho việc xây dựng các hệ thống an toàn (secure systems) trong đó lưu trữ và xử lý thông tin và truyền tin – giao dịch giữa các thành phần hệ thống ***đều xảy ra với sự tồn tại của các thế lực đối địch;*** một số chủ đề điển hình:
  - Các công cụ mã hóa (Encryption)
  - Các công cụ xác thực chủ thể (Entity authentication tools)
  - Xác thực thông tin và chữ ký điện tử
  - Thiết lập và quản lý khóa
  - and các công cụ giao thức bảo mật đa dạng

Các phương pháp điều khiển truy nhập

- Câu hỏi tình huống: Can user X use resource F with right (privilege) R?
  - Access Control Matrix
  - Discretionary Access Control
  - Mandatory Access Control
  - Role-based Access Control

Các phương pháp xác thực thực thể

Có 4 cách tiếp cận cơ bản

- What entity knows (*eg.* password)
- What entity has (*eg.* Identity card, smart card)
- What entity is (*eg.* fingerprints, retinal characteristics)
- Where entity is (*eg*. In front of a particular terminal)

Chủ đề: an toàn mạng máy tính

- Nắm vững các mối đe dọa và các dạng tấn công phổ biến trên mạng
  - Nắm vững một số hình thức tấn công mạng nguy hiểm và phổ biến hướng tới một so giao thức Internet cụ thể (vd. Tấn công SYN flood chống phá giao thức TCP)
- Các sản phẩm giao thức ATTT đã có: IPsec, SSL/TLS
- Nắm vững cách xây dựng các giải pháp phòng chống phổ biến: tường lửa (Firewall), Phát hiện xâm nhập (Intrusion Detection Systems)

ATTT trong Xây dựng phần mềm/chương trình/ ứng dụng Web

- Mã độc: Logic bomb, virus, worms, …
- Các lỗi lập trình phổ biến dễ bị lợi dụng: buffer overflow …
- Các kiểu tấn công khai thác các lỗi phổ biến
- Tấn công Web: command injection e.g. SQL injection, cross-site scripting …

ATBM cho Cơ sở dữ liệu

- Database Security Levels
- Reliability and Integrity
- Attacks against database
- Access Control

Tính riêng tư, Bản quyền số và Thương mại điện tử

- Một số chủ đề nóng xung quanh việc đảm bảo ATTT cho các dịch vụ Internet và transactions giao dịch mang
  - Controversies around level of user privacy: can perfect anonymity is allowed?
  - How to protect copyright of digital products?
  - How can we pay in securely and efficiently when doing e-commerce?

What is This Course About?

- Learn to think about security
  - Threats, defenses, policies
  - Software, human and environment factors
- Think as an attacker:
  - Learn to identify threats
- Think as a security designer:
  - Learn how to prevent attacks and/or limit their consequences
  - Understand and apply security principles
  - Learn tools that can defend against specific attacks, no silver-bullet solution

Lịch trình

- Giới thiệu cơ sở khoa học mật mã: các hệ mã cổ điển, đối xứng, khóa công khai, chữ ký số, hàm băm, quản lý khóa …
- Các phương pháp xác thực thực thể
- Các phương pháp quản lý truy nhập
- Các chủ đề mở rộng liên quan đến mạng máy tính, phần mềm và chương trình …

(Phần mở rộng tùy chọn mỗi năm)

Tài liệu môn học

- Giáo trình tiếng Việt: Giáo trình Cơ sở An toàn Thông tin (TS. Nguyễn Khanh Văn, NXB Đại học Bách Khoa Hà nội, 2015-2020)
- Một số sách giáo tiếng Anh phổ biến:
  - Introduction to Computer Security, Matt Bishop, Addison-Wesley Professional
  - Security in Computing, Charles P.Pfleeger, Prentice Hall
  - Cryptography And Network Security: Principles and Practices, William Stallings, Prentice Hall
- Tài liệu khác: Bộ slides và tài liệu liên quan có thể tài về từ trang Web của giảng viên

Bài tập nhóm – tự chọn

- An in-depth study at a certain specific problem/topic
  - Should relate your study to an in-class topic
  - Work should be considerably deeper than class material
  - Citation is a must: anything important point of view should be referred to a source
    - Various references, not just a couple
  - Should support your work by some practical component: implementation/experiment/installation…
- Your work must be really yours:
  - No full copy of part from Internet
  - Definitions, statement borrowed should be cited clearly
  - Your own writing!

Các chủ đề chính cho BTL:

- Classic cryptography: general notions in crypto
- Block ciphers and Symmetric Key Crypto systems
- Public Key Cryptosystems & hash functions & Digital Signatures
- Key Distribution and management
- Cryptographic Protocols
- Authentication
- Access Control
- Program and System Security
- Security in web-based applications
- Network attacks
- Security in e-commerce & E-payment systems

Website: users.soict.hust.edu.vn/vannk (hoặc thầy cô giảng dạy trực tiếp)

ĐẠI HỌC BÁCH KHOA

25 YEARS ANNIVERSARY SOICT

VIỆN CÔNG NGHỆ THÔNG TIN VÀ TRUYỀN THÔNG

SCHOOL OF INFORMATION AND COMMUNICATION TECHNOLOGY

Thank you for your attentions!



soict.hust.edu.vn/ fb.com/groups/soict